

Lab 11 (Phishing Emails in Action)

exercise 2

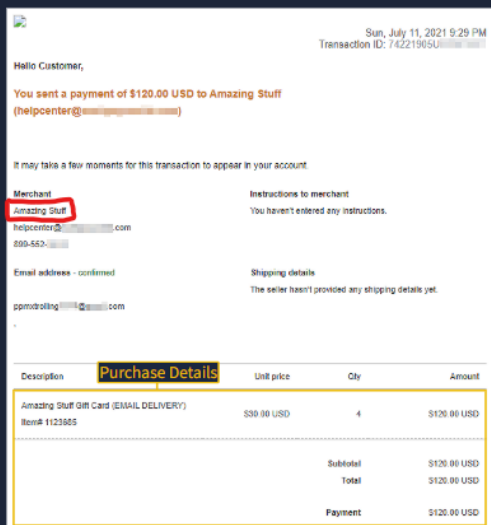
The focus is on understanding how phishing emails work in real-life situations

TASK 2: Cancel your order

- Spoofed Sender: The display name says "service@paypal.com," but the actual underlying email address is completely unrelated random gibberish.
- Mismatched Recipient: The email was not sent to the actual email address tied to the user's PayPal account.
- False Urgency: The subject line claims a purchase was made, tricking the victim into acting quickly out of fear or curiosity.
- Hidden Links: The "Cancel the order" button uses a shortened URL to hide its true destination. In this specific case, it weirdly redirects to Google, likely to confuse the victim or look harmless.

Email Body Analysis

Taking a look at the email body below, we can see the email is designed to appear as a legitimate email from PayPal with this email, and the only interactive element in the email is the "Cancel the order" button. Let's take a closer look.



Who is listed as the **Merchant** in the email body?

Amazing Stuff

✓ Correct Answer

TASK 3: Track your package

- **The Hook:** The subject line includes a fake tracking number. This exploits curiosity and routine habits, as people frequently click without thinking to check a package status.
- **Tracking Pixels:** The email contains a hidden, invisible image (named "Tracking.png"). When loaded, it secretly alerts the attacker's server that the email was opened. This confirms the email address is active, making it a target for future spam. (This is why email providers like Yahoo block images by default).
- **Malicious Links:** Checking the email's source code reveals that the tracking link points to a suspicious, unrelated domain rather than a real shipping company.

Answer the questions below

What root domain does the hyperlink in the above example point to?
Be sure to defang the URL.

devret[.]xyz

✓ Correct Answer

TASK 4: Download document here

- **Artificial Urgency:** The email claims the document download link expires the exact same day, pressuring the victim to act quickly without thinking.
- **Bad Grammar:** The message contains multiple grammatical errors, a classic sign that it did not come from a professional corporation.
- **Brand Confusion:** Clicking the "Download Fax" button triggers a chain of mismatched, fake pages. It starts by mimicking OneDrive, but then redirects to a page that uses Adobe branding with a tab title reading "Share Point Online." None of the URLs belong to Microsoft or Adobe.
- **Credential Harvesting:** The final fake login page is a trap. If the victim attempts to log in with their Outlook account, their username and password are stolen and sent directly to the attacker's server.

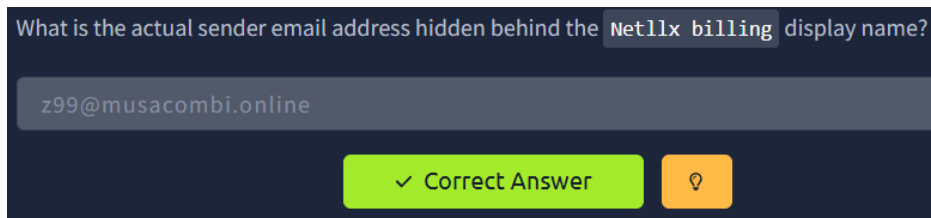
The attacker deployed a fake portal to capture and exfiltrate user credentials.
What is this type of attack called?

Credential Harvesting

✓ Correct Answer

TASK 5: Your account is on hold

- **Unrelated Sender Domain:** The sender's email address is z99@musacombi.online, which completely exposes the scam since it has nothing to do with Netflix.
- **Account Suspension Scare:** The email creates immediate urgency by claiming the user's account is suspended and access must be restored right away.
- **Sloppy Typos:** The email misspells the word "Netflix" multiple times throughout the body text, proving it is not a professional corporate communication.
- **Malicious PDF Attachment:** Instead of putting a link directly in the email text, the scammers hid it inside an attached PDF. Opening the PDF reveals a malicious link labeled "Update Payment Account."
- **Fake Support Number:** The contact phone number provided in the email is strange and does not match official, legitimate Netflix customer service channels.



TASK 6: Your recent purchase

- **Fake Sender & BCC:** The email actually comes from a random address (gibberish@sumpremed.com). The attacker used BCC (Blind Carbon Copy) to hide the true recipient list, while putting a fake, typo-ridden Apple address (donoreply@payament.apple.com) in the "To" line to look official.
- **Urgency with Blank Body:** The subject line creates a false sense of urgency about a recent purchase, but the email itself contains no text—only an attachment.
- **Dangerous .DOT Attachment:** The attachment is a Word document template (.DOT extension). These files are highly dangerous because they can automatically execute background scripts (macros) to install malware on your computer.
- **Fake Visual Receipt:** If opened, the document displays a fake Apple receipt. It uses convincing links containing words like "apps" and "ios" to trick the user into clicking and downloading further malicious content.

Answer the questions below

What does the acronym BCC stand for?

Blind Carbon Copy

✓ Correct Answer

What is the file extension of the attachment?

.dot

✓ Correct Answer

TASK 7: Scheduled shipment

- Unrelated Sender: The email address does not belong to DHL, serving as an immediate indicator of a scam.
- Curiosity & Worry Hook: The subject line mentions a shipping notice, exploiting the recipient's curiosity or anxiety about an unexpected or missing package.
- HTML Impersonation: The body of the email copies DHL's official logos, layout, and color schemes to look completely authentic.
- Broken Web Links: In the email's source code, standard links like "View this email as a web page" do not work. This is a deliberate tactic to force the victim to interact *only* with the attachment.
- Malicious Excel Attachment: The email contains an Excel file that acts as a trap. Once opened, it attempts to execute a hidden payload that runs regasms.exe—a legitimate Microsoft framework tool that attackers often hijack to run malware silently in the background.

What is the name of the executable that the Excel attachment attempts to run?

regasms.exe

✓ Correct Answer

TASK 8: Conclusion

Task 8 Conclusion

In this room, you analyzed a series of phishing attempts and developed the skills needed to distinguish legitimate communications from malicious ones. By examining email headers, body content, links, and attachments, you learned how to identify common red flags such as spoofed senders, suspicious domains, and deceptive social engineering techniques.

Further Learning

This is the second room of the Phishing Analysis module of the SOC Level 1 Path. You are encouraged to continue your learning with the walkthrough and challenge rooms below:

- Phishing Analysis Tools
- Phishing Prevention
- The Greenholt Phish
- Snapped Phish-ing Line

Answer the questions below

Complete the room and continue on your cyber learning journey!

No answer needed

✓ Correct Answer